EXPERIMENT NO: 02

HCSSBL701 – Vulnerability Assessment & Penetration Testing (VAPT) Lab

Course Name	Module Mapping	Outcome	Domain
Vulnerability Assessment & Penetration Testing Lab (HCSSBL701)	Module II: Network Scanning & Enumeration	LO3 (Cognitive Level: L2, L3)	Host Discovery, Port Scanning & Service/OS Fingerprinting

1. AIM

To sweep a live subnet for active hosts, enumerate the ports exposed on each host, fingerprint the services and operating systems behind those ports, and use the resulting attack-surface map to prioritise which findings need remediation first. The exercise is carried out across four linked stages:

- Stage 1: Host Discovery — identifying which addresses in the target subnet are currently live.
- Stage 2: Port Scanning — probing each live host to classify TCP ports as open, closed, or filtered.
- Stage 3: Service Detection — matching each open port to the application and version running behind it.
- Stage 4: OS Fingerprinting — inferring the host operating system from TCP/IP stack behaviour.

2. HARDWARE & SOFTWARE REQUIREMENTS

Category	Specification & Tools
Hardware Configuration	Intel Core i5 (or equivalent) processor, 8 GB RAM, 500 GB storage, functional NIC.
Operating System	Kali Linux (attacker/scanner machine) with Windows Server and Linux hosts as scan targets on the same lab VLAN.
Network Diagnostic Utilities	ip addr / ifconfig, ipconfig, ping, traceroute.
Scanning & Enumeration Tools	Nmap (host discovery, port scanning, service/version detection, OS fingerprinting, NSE scripts), Zenmap (GUI front-end, optional).
Documentation Tools	Microsoft Word, Microsoft Excel.

3. THEORY & BACKGROUND CONCEPTS

A tester cannot secure — or an attacker cannot target — what has not first been mapped. Network scanning answers that mapping question in stages, starting broad (which hosts exist) and narrowing with each step (which ports, which services, which platform). Running the stages in order, rather than probing every port on every possible address at once, keeps the scan efficient and keeps the traffic footprint on the network low enough to stay unobtrusive.

The four stages used in this exercise are described below.

Host Discovery

The scanner sends lightweight probes — ICMP echo requests, ARP requests on the local segment, or TCP probes to commonly-open ports — across every address in the target range, e.g. 10.10.30.0/24. Any address that fails to respond within the timeout is excluded from the remaining stages, so the rest of the scan only spends time on hosts known to be reachable.

Port Scanning

Each live host is then probed across a range of TCP or UDP port numbers. A TCP SYN scan sends a SYN packet per port and reads the reply: a SYN-ACK marks the port open, an RST marks it closed, and silence (behind a firewall) marks it filtered — all without ever finishing the three-way handshake, which keeps the scan quieter than a full connect scan.

Service & Version Detection

An open port only confirms that a process is listening, not what that process is. Version detection sends protocol-aware probes at each open port and matches the reply against a signature database, returning a specific application name and version string. This step is what turns a raw port number into something a tester can map against a known CVE.

OS Fingerprinting

Operating systems differ in small, non-standardised ways in how they implement the TCP/IP stack — initial TTL, window size, options ordering, and how they respond to malformed packets. By sending a set of specially-crafted probes and comparing the responses to a fingerprint database, the scanner narrows down the likely OS family and version, which in turn narrows down which exploits are even relevant to that host.

4. EXPERIMENTAL PROCEDURE & EXECUTION STEPS

Step 1 — Confirm the Scanning Host's Own Network Configuration

```
$ ip addr show
C:\> ipconfig /all
```

Note the scanning machine's own IP address, subnet mask, and default gateway, and identify the subnet that will be swept next.

Step 2 — Host Discovery (Ping Sweep)

```
$ nmap -sn 10.10.30.0/24
```

Sweep the full subnet to build a list of live hosts before any port probing begins.

Step 3 — Port Scanning

```
$ nmap -p- -T4 10.10.30.20
$ nmap -sS 10.10.30.20          # SYN (stealth) scan on default 1000 ports
```

For each live host from Step 2, enumerate open TCP ports across the full range, using a faster timing template where the lab network allows it.

Step 4 — Service & Version Detection

```
$ nmap -sV 10.10.30.20
```

Probe each open port found in Step 3 to identify the application and version banner behind it.

Step 5 — OS Fingerprinting

```
$ nmap -O 10.10.30.20
$ nmap -A 10.10.30.20            # combined OS + version + script + traceroute
```

Infer the target's operating system from its TCP/IP stack behaviour, then run the aggressive combined scan to consolidate every finding in one pass.

All scans were performed only against hosts within the authorised lab VLAN, with prior written permission from the lab administrator, in line with responsible and authorised testing practice.

5. OBSERVATIONS & DATA RECORDING

Table 1: Nmap Scan Execution Log

Command Executed	Purpose / Objective	Observed Output / Result
ip addr show / ipconfig /all	Confirm the scanning host's own IP address and subnet before scanning	IP: 10.10.30.8, Subnet Mask: 255.255.255.0, Gateway: 10.10.30.1 (subnet under test: 10.10.30.0/24)
nmap -sn 10.10.30.0/24	Host discovery — ping sweep to identify live hosts on the subnet	6 hosts up: 10.10.30.1 (Gateway), 10.10.30.8 (self), 10.10.30.12, 10.10.30.20, 10.10.30.25, 10.10.30.40. Scan completed in 5.6 seconds.
nmap -p- -T4 10.10.30.20	Full TCP port scan (all 65535 ports) to identify open ports on a live host	6 open ports found: 21/tcp, 23/tcp, 25/tcp, 53/tcp, 139/tcp, 445/tcp. 65529 ports filtered/closed.
nmap -sV 10.10.30.20	Service/version detection on the open ports discovered	21/tcp open ftp vsftpd 2.3.4; 23/tcp open telnet Linux telnetd; 25/tcp open smtp Postfix smtpd; 53/tcp open domain ISC BIND 9.16.1; 139/tcp open netbios-ssn Samba smbd 4.6.2; 445/tcp open microsoft-ds Samba smbd 4.6.2
nmap -O 10.10.30.20	OS fingerprinting based on TCP/IP stack response characteristics	OS details: Linux 2.6.9 - 2.6.33 (older server kernel); Aggressive OS guess: 89% match. Network Distance: 1 hop.
nmap -A 10.10.30.20	Aggressive scan combining OS detection, version detection, script scanning and traceroute in one pass	Confirmed prior findings; additionally flagged the vsftpd 2.3.4 build (known backdoored version) and cleartext Telnet credential exposure as the two highest-priority findings for the report.

Table 2: Host Exposure Summary

Host Scanned	Open Ports	Services / OS Identified	Risk Vector
10.10.30.12	135, 139, 445, 3389	SMB (Windows Server 2019), RDP	RDP and SMB both reachable from the general lab VLAN; a primary target for lateral movement and credential brute-forcing.
10.10.30.20	21, 23, 25, 53, 139, 445	vsftpd 2.3.4, Telnet, Postfix, ISC BIND 9.16.1, Samba 4.6.2 (legacy Linux build)	Highest-priority host: the FTP daemon version matches a known backdoored release, and Telnet exposes credentials in cleartext.
10.10.30.40	80, 8443	nginx, unbannered web admin panel (Linux)	Unidentified admin interface on a non-standard HTTPS port suggests a forgotten or shadow-IT management console.

6. PREVENTIVE MEASURES & HARDENING RECOMMENDATIONS

- Remove or replace the vsftpd 2.3.4 build immediately — this version corresponds to a publicly known backdoor and should never be reachable even on an internal VLAN.

- Disable Telnet entirely and standardise on SSH for remote administration, since Telnet transmits credentials and session data unencrypted.
- Restrict RDP (3389) to a jump host or VPN-only access path rather than exposing it directly on the LAN.
- Patch BIND and Samba to their current stable releases and disable zone transfers / null sessions where not explicitly required.
- Rate-limit or firewall ICMP/ARP responses at the host level to slow down discovery reconnaissance.
- Inventory and decommission unbannered or forgotten services such as the admin panel on 10.10.30.40 before they are discovered externally.
- Repeat this authorised scanning procedure on a periodic schedule so newly opened ports or reintroduced legacy services are caught internally first.

7. CONCLUSION

This exercise repeated the four-stage network scanning and enumeration workflow specified in the HCSSBL701 syllabus against a separate lab subnet. The host-discovery sweep located six live addresses without probing unused space, after which the port scan, service-detection pass, and OS fingerprinting stage progressively converted three of those hosts into a concrete exposure picture: a Windows host with RDP and SMB reachable, a legacy Linux host running a backdoored FTP daemon alongside cleartext Telnet, and an unbannered shadow-IT admin panel. The exercise reinforces that scanning and enumeration alone — before any exploitation is attempted — is often enough to surface the findings that matter most, and that the backdoored and cleartext services identified here should be treated as the top remediation priority.